

Recap

The main novelty of the HTTP/3 protocol is the use of the QUIC protocol on top of the UDP transport protocol

This allows a faster setup of the connections between clients and servers (1 or 0 RTTs), thus improving the efficiency in terms of Page Load Time

HTTP/3 implementation is not straightforward

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

133

Cookies



The problem is to identify/track users on the web to customize/enhance their web experience using a stateless protocol (creation of a logical user session)

IP address of the client and/or **User-Agent** string are not sufficient for tracking user activities

A cookie is a small text file (up to 4,096 bytes, max 50 per domain) used to implement the concept of status in the web [[RFC 6265 "HTTP State Management Mechanism"](#) published in 2011, first RFC in 1997]

Cookies are used for everything the server should (or would like to) remember about a client (e.g., authentication, managing logical user sessions, identifying returning users, content customization, web analytics, targeted advertisements)

Cookies are active identifiers stored on user devices

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

134

Cookies implementation

Cookie implementation is based on four components:

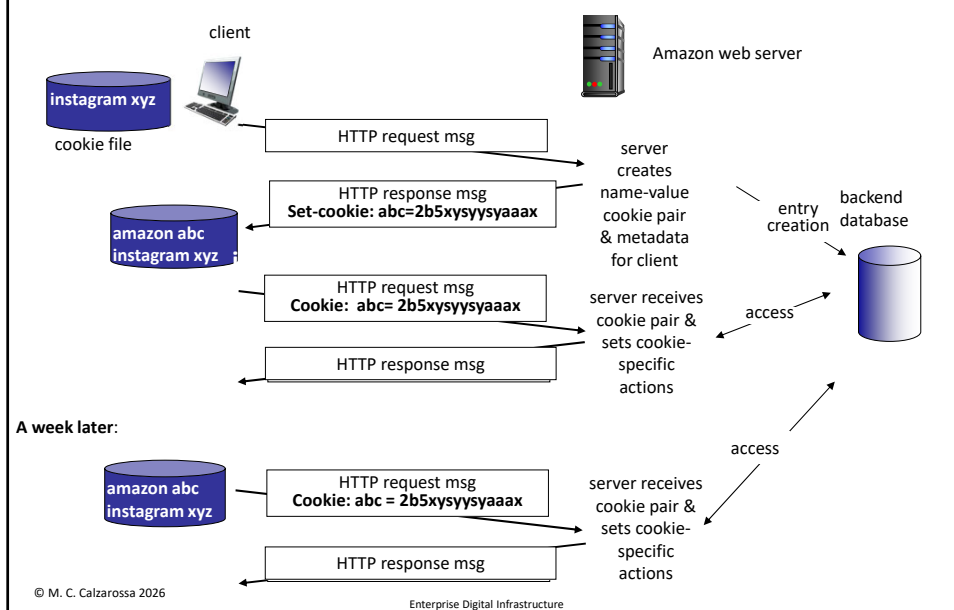
- Two specific header fields
 - **Set-cookie:**
sent by web servers in HTTP response messages
 - **Cookie:**
sent by clients in HTTP request messages
- One file on the client side managed by the browser
- One backend database on the server side managed by the web server

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

135

Implementation



© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

136

Cookie content

A cookie consists of a unique ID, that is, a (name, value) pair, plus some metadata

Metadata refers to the “scope” of each cookie (i.e., what URL the cookie should be sent to):

- host(s) allowed to receive the cookie (*Domain:*)
- path to which the cookie is applicable (*Path:*)

Other information refers to the expiration time of the cookie (*Expires:*) [max 13 months according to the EU ePrivacy Directive]

Cookies can set flags, such as *HTTPOnly* and *Secure*, to mitigate the risks associated with security threats (e.g., XSS) or limit the scope to secure channels

Sensitive information should never be stored in a cookie to avoid cookie poisoning attacks (e.g., session hijacking)

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

137

Example

Cookie name & value

The diagram shows a cookie string: `_cf_bm:"AQQXcE01GiOBozb70ASOX22d120ILMNH4JvjZMNyZg-1777407...aXxuMrZa9UDKVIlbvh3No8kVY43fB31yriAlxjBhX5uV6F9Fkw"`. A red box highlights the entire string. Two callout boxes point to parts of the string: one labeled "Attribute name" points to the opening quote and colon, and another labeled "Attribute value" points to the closing quote.

```
_cf_bm:"AQQXcE01GiOBozb70ASOX22d120ILMNH4JvjZMNyZg-1777407...aXxuMrZa9UDKVIlbvh3No8kVY43fB31yriAlxjBhX5uV6F9Fkw"
Created:"Tue, 28 Apr 2026 20:20:32 GMT"
Domain:".portale.unipv.it"
Expires / Max-Age:"Tue, 28 Apr 2026 20:50:32 GMT"
HostOnly:false
HttpOnly:true
Last Accessed:"Tue, 28 Apr 2026 20:20:32 GMT"
Path: "/"
SameSite:""
Secure:true
Size:205
Updated:"Tue, 28 Apr 2026 20:20:32 GMT"
```

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

138

Cookie classification

Three different ways to classify cookies:

- *Duration*: how long a cookie will last
- *Provenance*: who generates the cookie
- *Purpose*: what goal a cookie serves

Various categories

Some cookies may qualify for multiple categories

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

139

Cookie duration/provenance

Cookies can be grouped in two categories according to their *duration*:

- *Session cookies*: temporary cookies expiring when browser is closed or once a session ends
- *Persistent cookies*: cookies that remain on user devices (e.g., disks) until browsers (or users) delete them (depending on expiration date and time)

Cookies can be grouped in two additional categories depending on who generates/manages them:

- *First party*: cookies generated by the owner/provider of the web application
- *Third party*: cookies generated by external organizations with no direct relationships with the provider (e.g., advertisers, data controllers)

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

140

Cookie purpose

Cookies can also be grouped according to their main purpose:

session/
persistent
first party

- *Strictly necessary (technical) cookies*: essential cookies necessary for using a web application and all its features (e.g., accessing restricted areas of the site, holding items in the shopping cart)
- *Preference (functional) cookies*: cookies used for allowing a web service to remember past choices of users (e.g., language preferences, credentials for automatic login)
- *Statistics (performance) cookies*: cookies used to collect information about web application usage to improve its functions (e.g., navigation patterns, clicked links)
- *Marketing (profiling) cookies*: cookies used for tracking online activities and help advertisers deliver more relevant ads

session
first-party

persistent
third or
first-party

persistent
third-party

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

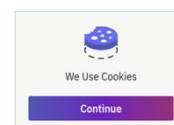
141

Cookies & privacy

Cookies are very intrusive and affect our privacy

To what extent can we “control” cookies?

1. Enable/disable cookies
 - Disable all cookies, but many web services will stop working
 - Enable all cookies, but this will affect our privacy
 - Enable first party cookies & disable third party cookies
2. Store/remove cookies
 - Store cookies until they expire (not very soon)
 - Remove cookies manually (it takes time)
 - Remove cookies when closing the browser



© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

142

Cookie legislation

To protect the privacy of EU citizens, EU Parliament issued Directive 2009/136/EC, a general directive on the processing of personal data and the protection of privacy in electronic communications that includes a specific article about cookies



Member states adopted the *EU ePrivacy Directive* (e.g., in Italy Law 69/2012, articles 121 & 122 about cookies); in 2014 Italian Data Protection Authority published rules/guidelines for website owners

Since January 2015 all websites owned by EU companies/organizations and international sites that cater to EU citizens must comply with these regulations

Each time users visit a website, they must be informed if cookies are being used and they should have the option to accept/refuse them

Since May 25, 2018 GDPR strengthened these rules (especially for cookies able to identify individuals and their personal data)

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

143



Guidelines on cookies

In June 2021 the Italian Data Protection Authority issued new [guidelines](#) on the use of cookies and tracking tools; since January 9, 2022 all website owners must comply with these guidelines ([executive summary](#))

Guidelines take into account GDPR and comments/complaints received from a public consultation with different stakeholders

The main objective is to expand and enhance the decision power of online users with respect to the usage of their data

Information on cookies and consent to store cookies (i.e., informed consent)

Information on cookies should be provided by using a simple and accessible language (no legalese/technical) without any discrimination towards individuals needing assistive technologies

A consent is an explicit action that unambiguously signals the user intention

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

144

Guidelines on cookies (cont'd)

Information should be provided using a suitably sized pop-up banner that includes:

- A warning about the use of cookies and their purposes
- A link to the privacy policy (e.g., recipients of personal data, data storage periods, how to exercise rights under GDPR)
- A warning to the effect that if the banner is closed the default settings are left unchanged

The banner should contain

- A command to close the banner and keep the default settings
- A button to accept all cookies
- A link to an additional dedicated area where users can select the cookies individually

The banner should not be shown at every access (to avoid user frustration)

Scrolling and cookie wall are generally unsuitable to obtain users' consent

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

145

Guidelines on cookies (cont'd)

For authenticated users, the matching of data related to browsing across devices requires users' prior consent

The main changes under the GDPR can be summarized as follows:

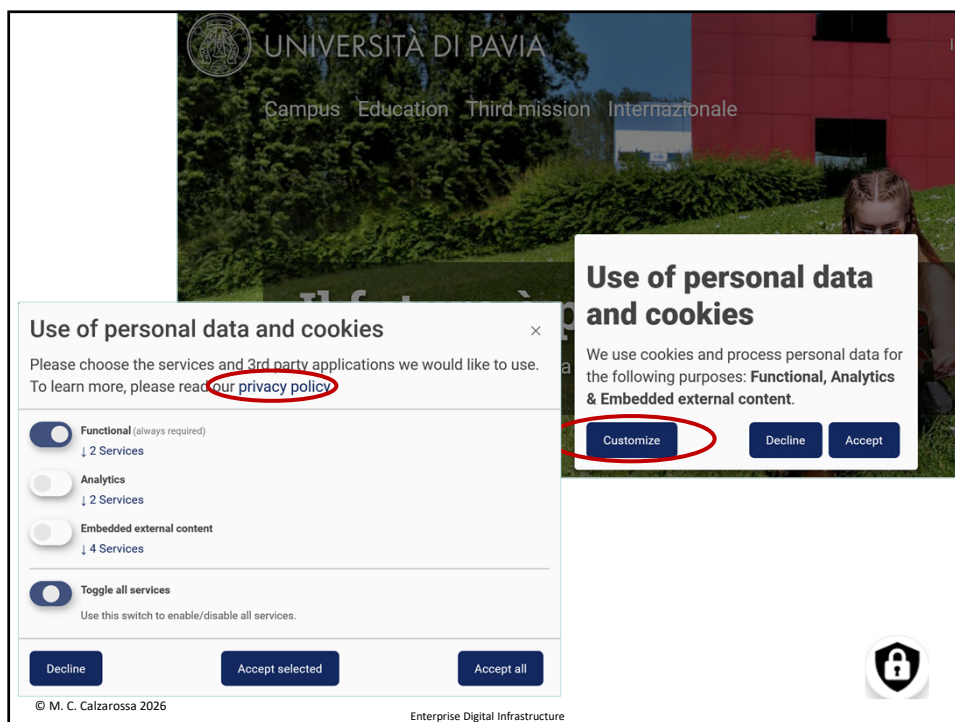
- Accountability (i.e., implementation of appropriate technical and organizational measures to comply with data protection legislation)
- Expanded information obligations (i.e., data storage and accessibility periods to be specified)
- Enhanced consent (i.e., it must be 'unambiguous')
- Compliance with privacy by design and privacy by default principles for effective data protection

Administrative sanctions in case of violations of the regulations

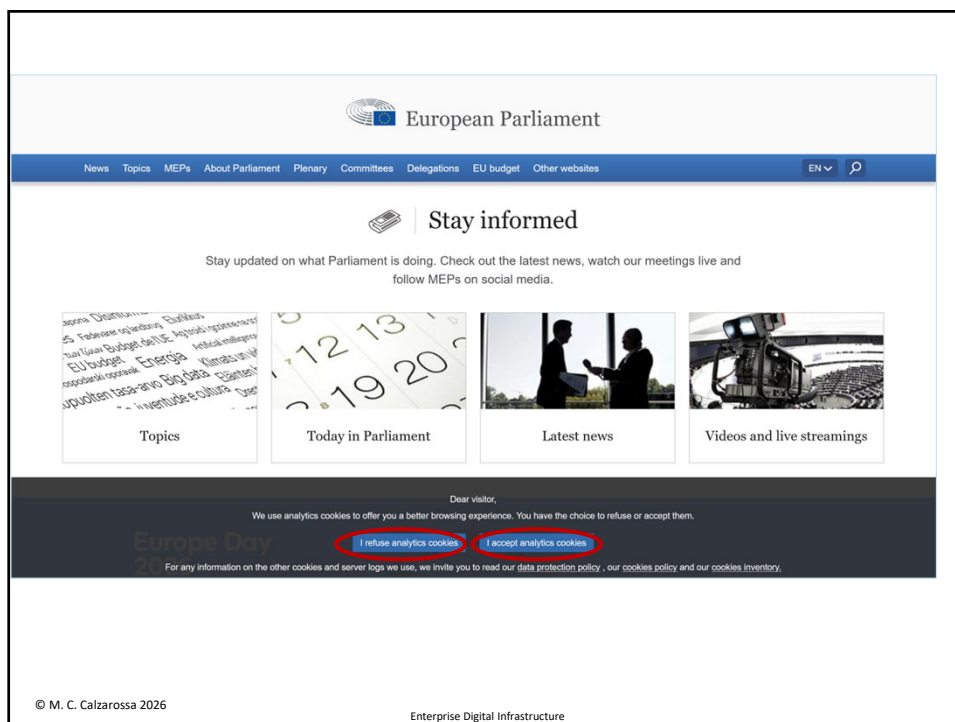
© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

146



147



148

Cookie fines: examples

8 Companies Hit With Cookie Consent Fines for Non-Compliance

By Shreya | March 3, 2026

- 1. Example 1: Yahoo fined €10 million for cookie consent violations
2. Example 2: Roularta Press Group fined €50,000 for cookie consent violations
3. Example 3: Vueling fined €30,000 for not having a cookie consent banner
- 4. Example 4: TikTok fined €5 million for deceptive cookie consent
5. Example 5: Company fined €15,00 for cookie consent violations
6. Example 6: Two companies fined €20,000 and €30,000 for cookie consent violations
- 7. Example 7: Sephora fined \$1.2 million for failure to provide opt-out of sales option
- 8. Example 8: Microsoft fined \$60 million for cookie practices

On 29 December 2023, the French Data Protection Authority (CNIL) fined YAHOO EMEA LIMITED €10 million for failing to respect the choice of Internet users who refused cookies on its "Yahoo.com" website and for not allowing users of its "Yahoo! Mail" messaging service to freely withdraw their consent to cook.

The CNIL found that for tiktok.com's users, it was not as easy to refuse online trackers as to accept them. The authority also found that internet users were not sufficiently informed about TikTok's use of the cookies.

A cookie was automatically placed on users' terminals when they visited the search engine "bing.com" without their knowledge or consent.

© M. C. Calzarossa 2026



Failed to notify consumers that it was selling their personal information

Failed to process consumer "Do Not Sell My Personal Information" opt-out requests

Did not address these alleged violations within the 30-day cure period.

149

News headlines



France fines Shein \$176 million over cookies

By Helen Reid
September 4, 2025 12:22 AM GMT+2 · Updated September 4, 2025



Coolblue fined for unsolicited use of cookies

24 December 2024 · Theme: Cookies

The Dutch Data Protection Authority (Dutch DPA) has imposed a fine of 40,000 euro on Coolblue for unlawful processing of personal data in 2020. At the time, the company used cookies to collect personal data from visitors of the online shop without obtaining their express consent. Coolblue automatically assumed that visitors would consent to this. That is not allowed.

Microsoft ordered to address cookie storage without users' consent

Last updated: 19.08.2024

Dutch Data Protection Authority continues its hunt for bad cookie banners

Legal news
17 Apr '25 · Author(s): Lianne Bruggeman

Italian Garante Fines Digital Marketing Company Over Use of Dark Patterns

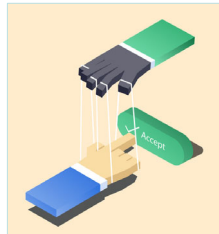
By Kristof Van Quathem & Laura Somalini on May 12, 2023

More specifically, the Garante argued that Ediscom often used misleading graphic interfaces and unclear submission procedures. For example, if a user did not consent to receive marketing communications or to allow the communication of their personal data to third parties for marketing purposes, a pop-up showed up again and prompted the user to provide consent that had already been denied.

© M. C. Calzarossa 2026

150

Dark patterns



[Cheat sheet](#)

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

151

EU watchdogs agree on how to handle certain cookie consent dark patterns

Natasha Lomas @riptari / 1:02 PM GMT+1 • January 20, 2023

[Comment](#)

Cookie consent banners that use blatant design tricks to try to manipulate web users into agreeing to hand over their data for behavioral advertising, instead of giving people a free and fair choice to refuse this kind of creepy tracking, are facing a coordinated pushback from the European Union's data protection regulators.

It appears that some cookie banners displayed by several controllers contain a button to accept the storage of cookies and a button that allows the data subject to access further options, but without containing a button to reject the cookies.

It appears that several controllers provide users with several options (typically, representing each category of cookies the controller wishes to store) with pre-ticked boxes on the second layer of the cookie banner (after the user clicked on the "Settings" button of the first layer).

Deceptive "Link Design" It appears that some cookie banners displayed by several controllers contain a link, not a button, as an option to reject the deposit of cookies (direct link to reject or link to a second layer where a user can reject the deposit of cookies).

It appears that the configuration of some cookie banners in terms of colours and contrasts of the buttons ("contrast ratio between the accept button and the background" – type D practice) could lead to a clear highlight of the "accept all" button over the available options.

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

152

Fingerprinting

Fingerprinting is a sophisticated passive tracking technology much more intrusive than ordinary cookies

It aims at collecting detailed information about devices (e.g., browser/operating system type/version, screen resolution, architecture type, fonts, plugins, microphone, camera, battery) for identifying users

Browser fingerprinting is defined as a “cookieless monster” because it does not require to install/store anything on the user device, so there is no user control

Information collected from HTTP header fields, JavaScript attributes, plugin details, TLS handshake, font settings, ...

[FingerprintJS](#) is an open-source library for browser fingerprinting that queries browser attributes and computes a hashed visitor identifier

Canvas fingerprinting abuses the HTML5 canvas element to run a JavaScript that generates an image to be used as a unique identifier

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

153

Fingerprinting (cont'd)

Fingerprinting can be used for many benign and malicious purposes (e.g., to fight fraud or credential hijacking, detect bot attacks, track users across websites, deliver exploits or malware customized to device settings)

Technology completely invisible to the users (passive)

GDPR does not ban the use of fingerprinting, but it requires companies to be transparent about data collection and ask for consent when personal data processing is involved

Companies are often opaque and unclear in the ways they track users

Fingerprinting defense is very difficult (e.g., adding some randomness/noise in the fingerprinting semi-identifiers, such as **User-Agent** string)

Browsers provide mechanisms to protect against known fingerprinting by blocking third-party requests to companies that are known to track users

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

154

Browsers solutions



Basic

Allows most trackers across all sites

Content and ads will likely be personalized

Sites will work as expected

Balanced (Recommended)

Blocks trackers from sites you haven't visited

Content and ads will likely be less personalized

Sites will work as expected

Strict

Blocks a majority of trackers from all sites

Content and ads will likely have minimal personalization

Parts of sites might not work

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

155



Enhanced Tracking Protection



Trackers follow you around online to collect information about your browsing habits and interests. Firefox blocks many of these trackers and other malicious scripts.

[Learn more](#)

[Manage Exceptions...](#)

☐ Standard

Balanced for protection and performance. Pages will load normally.

☐ Strict

Stronger protection, but may cause some sites or content to break.

☒ Custom

Choose which trackers and scripts to block.

☒ Cookies

All cross-site cookies (may cause websites to break)

☒ Tracking content

In all windows

☒ Cryptominers

☒ Known fingerprints

☒ Suspected fingerprints

In all windows

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

156



AM I UNIQUE ?

Service aimed at studying the diversity of browser fingerprints and providing developers with data to help them design good defence mechanisms (*crowdsourced data*)

ARE YOU UNIQUE ?

Yes! You are unique among the 5051836 fingerprints in our entire dataset.

The following informations reveal your OS, browser, browser version as well as your timezone and preferred language. Moreover, we show the proportion of users sharing the same elements.



windows
Operating system

45.16 %



firefox
Web browser

34.13 %

en
Language

66.10 %

UTC+02:00
Timezone

13.81 %

Yes! You are unique among the 5051843 fingerprints in our entire dataset.

The following informations reveal your OS, browser, browser version as well as your timezone and preferred language. Moreover, we show the proportion of users sharing the same elements.



windows
Operating system

45.16 %



chrome
Web browser

48.27 %

en
Language

66.10 %

UTC+02:00
Timezone

13.81 %

© M. C. Calzarossa 2026

157

HTTP HEADERS ATTRIBUTES

Attribute	Similarity ratio	Value
1 - User agent ⓘ	0.04 %	Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:150.0) Gecko/20100101 Firefox/150.0
2 - Accept ⓘ	20.48 %	text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
3 - Content encoding ⓘ	59.03 %	gzip, deflate, br
4 - Content language ⓘ	20.59 %	en-US,en;q=0.9
5 - Upgrade Insecure Requests ⓘ	89.21 %	1
6 - Referer ⓘ	11.96 %	https://www.google.com/

© M. C. Calzarossa 2026 Enterprise Digital Infrastructure

158